

Guardian Group Compliance Portal

Production-Grade, Secure & Scalable — Technical Overview

HR • Health & Safety • Employment Law

What does “production-grade” mean?

It means the portal is built the same way serious commercial software is built — not as a prototype or a quick fix, but with the foundations that allow it to grow, stay secure, and be relied upon by real businesses day to day. The Guardian Group Compliance Portal covers HR, Health & Safety, and Employment Law, and is built to handle the sensitivity and scale that entails.

Built on the Right Foundations

The technology stack was chosen deliberately. Every component is proven at enterprise scale.

Layer	Technology	Why it matters
User interface	React + TypeScript	Used by Facebook and Netflix — battle-tested with a huge security community. TypeScript catches bugs before they ship.
Database	PostgreSQL	Used by banks and governments — decades of security patches and proven reliability at scale.
Data layer	Drizzle ORM	Prevents an entire class of database attacks. Enforces data integrity in code, keeping the schema consistent.
File storage	Google Cloud Storage	The same infrastructure that powers Google Drive — unlimited, auditable, and access-controlled.
API	RESTful JSON	Industry-standard, individually secured endpoints. Integration-ready for third-party systems or a future mobile app.
Backend	Express.js	Lightweight, widely understood, and easy to audit and maintain.

Security — Layer by Layer

Security is not a single feature — it is built into every layer of the portal.

Proving who you are

- Passwords stored in a scrambled, one-way format — unreadable even if the database were ever stolen
- Two-factor authentication (2FA) with an authenticator app and backup recovery codes
- Mandatory 2FA for all user roles — currently being rolled out across the portal
- CAPTCHA-style bot check on the login page to block automated attacks
- Too many failed login attempts triggers a temporary account lockout

Staying logged in safely

- Login sessions stored in the database, not just a browser cookie that could be copied or stolen
- Sessions encrypted and only transmitted over secure (HTTPS) connections
- Sessions automatically expire after a period of inactivity — unattended screens are protected

Who can see and do what

- Every user has a defined role: Admin, Consultant, or Client
- Every action — not just every page — is checked against that role on the server
- Clients only ever see their own company’s data; there is no way to access another organisation’s records by

guessing a URL

- Sensitive areas (confidential cases, admin reports, shared documents) have individual access checks on top of role checks

Keeping bad data out

- Every form submission is validated on the server before anything is stored
- Database queries are structured to completely prevent SQL injection — a classic hacking technique where malicious commands are hidden in a form field
- TypeScript enforces data shapes across the whole codebase, making an entire category of bugs impossible by design

Web-level protection

- Security headers tell browsers to be strict about what they load and run
- Content Security Policy acts as a whitelist — only approved sources can deliver scripts or files to users
- Rate limiting prevents anyone from flooding the system with automated requests
- Passwords and sensitive data are never written to server logs
- Cloudflare Turnstile bot protection is active on the login page

Penetration Test Readiness

Security Check	Status
Strong password hashing	☒ In place
Brute-force lockout	☒ In place
Two-factor authentication (2FA)	☒ In place
Mandatory 2FA for all roles	☐ In development
SQL injection prevention	☒ In place
Secure, database-stored sessions	☒ In place
Session idle timeout	☒ In place
Security headers & Content Security Policy	☒ In place
Role-based access control	☒ In place
HTTPS only (enforced)	☒ In place
Bot protection on login	☒ In place
CSRF token	☒ Recommended addition
Rate limit fine-tuning	☒ Can be tightened

Once mandatory 2FA is live for all roles, the portal will tick virtually every box a professional penetration testing firm would check. The two remaining items are minor and straightforward to address.

Scalability — Built to Grow

The portal is designed to handle more users, more companies, and more data without requiring a rebuild.

The database scales with you

PostgreSQL is used by some of the world's largest organisations. Adding more clients or more sites is a matter of adding rows — the architecture does not change.

File storage is unlimited

Documents, PDFs, and uploads live in Google Cloud Storage, not on the server. There is no ceiling on how many files the portal can hold, and access to every file is logged.

The API is separation-ready

Because the front-end and back-end communicate through a clean, standard API, the two can be scaled independently. If the portal needed to handle ten times the traffic, the back-end could be scaled up without touching the user interface.

Multi-tenancy is built in

The portal was designed from day one to serve multiple companies, each with multiple sites and users, all isolated from each other. Adding a new client organisation is normal operation, not a structural change.

Integration-ready

The RESTful API means the portal can connect to third-party systems — HR software, payroll, or other compliance tools — without a rebuild. It is also ready for a mobile app if that direction is ever taken.

Summary

The Guardian Group Compliance Portal covers HR, Health & Safety, and Employment Law, and is built on the same technology stack used by serious commercial software products. Its security is layered — protecting the login, the session, the data, and the API independently — with mandatory two-factor authentication on its way for all users. Its database, file storage, and API are all designed to grow with the business, with no artificial ceilings. It is not a prototype; it is a production-grade compliance platform built to be trusted with real business data.

